

LLM-Powered Cybersecurity Maturity Assessment Tool

Emre Yavuz
Department of Computer Engineering
Gebze Technical University
Kocaeli, Türkiye
e.yavuz2020@gtu.edu.tr

Abstract— In today’s rapidly evolving digital landscape, organizations are increasingly exposed to sophisticated cyber threats that cause severe financial and reputational harm. Studies show that companies affected by cybersecurity incidents face annual losses exceeding \$2 million, while global damages from ransomware alone surpass \$5 billion. These vulnerabilities often arise from insufficient awareness and outdated security practices. This project addresses the gap by introducing an AI-driven chatbot powered by Large Language Models (LLMs) to assess an organization’s cybersecurity maturity through an interactive and adaptive questionnaire. The chatbot analyzes responses in real time, dynamically tailoring follow-up questions to explore critical areas more deeply or move forward efficiently. This ensures a thorough, context-aware evaluation of cybersecurity posture. The system also generates actionable insights, offers tailored recommendations, and streamlines the assessment process. By aligning cybersecurity strategies with organizational objectives, this approach enhances resilience and fosters continuous improvement across security practices.

Keywords: AI Chatbot, Adaptive Questionnaire Cybersecurity, Maturity Assessment, Large Language Models (LLM)

I. INTRODUCTION

As digital systems become more interconnected and integral to daily operations, organizations face an unprecedented surge in cyber threats—ranging from ransomware and phishing to sophisticated, state-sponsored attacks. These threats are not only growing in volume but also in complexity, often exploiting minor misconfigurations or overlooked vulnerabilities to cause severe financial and reputational damage.

While many organizations implement basic cybersecurity measures, traditional maturity assessment methods often fail to provide a clear, up-to-date picture of their security posture. These assessments are typically manual, time-consuming, and static, making them poorly suited to the dynamic threat

landscape. They also lack the adaptability required to address the specific needs, size, or infrastructure of different organizations.

To address these limitations, this project introduces an AI-powered chatbot built on Large Language Models (LLMs), designed to conduct interactive and adaptive cybersecurity maturity assessments. Unlike static questionnaires, this system dynamically adjusts its line of questioning based on prior responses, enabling deeper investigation into critical areas. The chatbot analyzes input in real time, evaluates maturity levels across predefined domains, and generates actionable recommendations.

This adaptive, context-aware approach not only enhances the depth and relevance of assessments but also facilitates alignment with organizational objectives. By integrating seamlessly with task management systems like Redmine, the tool supports both reporting and follow-up, providing a continuous improvement loop for cybersecurity practices. Ultimately, the system aims to reduce assessment overhead, personalize recommendations, and strengthen overall cyber resilience.

II. BACKGROUND

To establish the rationale for an LLM-Powered Cybersecurity Maturity Assessment Tool, it is important to understand the historical development of maturity assessment models, the emergence of artificial intelligence—particularly Large Language Models (LLMs)—in cybersecurity, and the rise of adaptive systems that enable more responsive and interactive evaluations.

A. Evolution of Cybersecurity Maturity Assessment

Cybersecurity maturity refers to the extent and effectiveness of an organization’s processes, capabilities, and policies in managing digital risks. Early assessment methods relied on static checklists or informal audits based on generalized best practices. Over time, structured frameworks such as the **Cybersecurity Capability Maturity Model (C2M2)**, **ISFAM**, and **O-ISM3** were introduced to offer more systematic evaluations across defined domains.

Despite their usefulness, these models are often difficult to implement in smaller organizations due to their complexity and lack of adaptability. Widely recognized standards such as **ISO/IEC 27001** and the **NIST Cybersecurity Framework** provide robust guidance for building and assessing information security management systems, but they often assume a baseline technical maturity and require expert facilitation. This limits their accessibility as self-assessment tools, especially in evolving threat landscapes.

This gap has driven the need for more **context-aware and dynamic tools** that allow organizations to evaluate their cybersecurity maturity with greater flexibility and operational relevance.

B. Artificial Intelligence and Large Language Models in Cybersecurity

Artificial Intelligence (AI) has become a foundational element in modern cybersecurity, powering systems for anomaly detection, threat prediction, and automated response. A **Large Language Model (LLM)** is a form of AI trained on vast corpora of text data, enabling it to generate coherent, context-aware language and interpret complex inputs.

In the context of cybersecurity maturity assessment, LLMs provide a powerful alternative to static surveys by enabling dynamic, interactive assessments. When integrated into chatbot interfaces, LLMs can analyze both structured (e.g., multiple-choice) and unstructured (free-text) responses, provide contextual interpretations, and generate real-time, personalized follow-up questions. This transforms the evaluation process into a more conversational, adaptive, and user-friendly experience, while also improving the depth and accuracy of results.

C. Adaptive Systems and Interactive Assessment Tools

An **adaptive questionnaire** is a dynamic assessment mechanism that modifies its content based on prior responses, allowing for more relevant and focused interactions. This contrasts with static tools, which often present the same set of questions regardless of organizational context or maturity.

The combination of LLM-powered chatbots and adaptive logic enables a tailored evaluation path. High-performing domains can be bypassed, while areas of weakness receive deeper probing. This real-time adaptivity enhances the assessment's value without increasing user burden.

Moreover, integrating assessment results with task management platforms such as **Redmine** allows identified gaps to be converted directly into actionable remediation tasks. This bridges the divide between insight and execution, ensuring that maturity evaluations lead to measurable improvements in cybersecurity posture.

This project builds on these technological advancements by combining LLM-based natural language understanding, adaptive assessment sequencing, and workflow integration. The result is a scalable, interactive system designed to offer efficient, accurate, and actionable cybersecurity maturity evaluations aligned with modern organizational needs.

III. METHODOLOGY

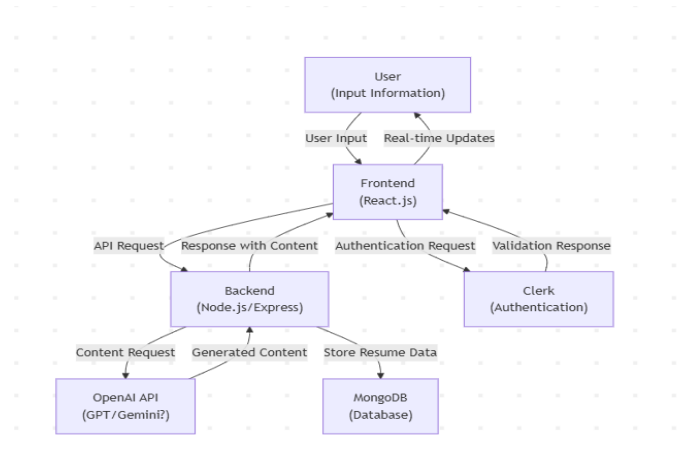
The proposed system employs a multi-faceted methodology to conduct dynamic cybersecurity maturity assessments, broken down into the following key stages:

Domain Definition: Eighteen cybersecurity domains are identified and rigorously aligned with internationally recognized standards, particularly the NIST Cybersecurity Framework (CSF) and ISO/IEC 27001. These domains serve as the foundational structure for the assessment content, question categorization, and subsequent scoring logic.

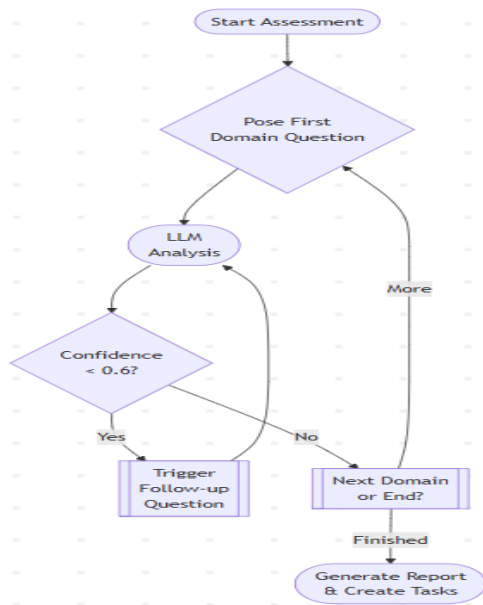
LLM Fine-Tuning: A pre-trained Large Language Model (LLM) is fine-tuned using a curated dataset of over 12,000 labeled question-answer (Q-A) pairs. These pairs are derived from authoritative sources, including the cybersecurity maturity questionnaire model by Ozkan and Spruit and NIST IR 8286 guidance, thereby ensuring the model's relevance and accuracy across both technical and organizational maturity contexts.

Questionnaire Design: A multi-level hierarchical question bank is meticulously developed. This bank comprises 140 focus-area questions strategically organized across three distinct maturity tiers: Foundational, Managed, and Optimized. Complementing these are 24 situational branching questions specifically designed to tailor assessments based on an organization's unique operational context, effectively mirroring the personalized guidance approach proposed in the Ozkan and Spruit research.

Adaptive Assessment Flow: An intelligent adaptive logic engine orchestrates the sequence and selection of questions dynamically, primarily utilizing response-based confidence scores derived from the LLM's analysis. When the certainty of a response falls below a predefined threshold (e.g., confidence < 0.6), targeted follow-up questions are automatically triggered to probe deeper into that specific domain, significantly enhancing assessment precision and granularity. Each answer provided contributes a weighted score towards the overall maturity level calculated for the associated cybersecurity domain.



As shown in Fig. 2. Detailed data flow between system components during an active assessment session.



As shown in Fig. 2. Adaptive assessment logic driven by LLM confidence scoring.

Data Capture and Security: All assessment responses, corresponding maturity scores, and relevant metadata are securely stored in a PostgreSQL database. To uphold privacy standards and comply with regulations such as GDPR, Personally Identifiable Information (PII) is systematically anonymized. Furthermore, data versioning is enabled within the database to support traceability and historical analysis across multiple assessment cycles for a given organization.

Reporting and Task Management Integration: Upon the successful completion of an assessment, the system automatically generates a structured and comprehensive report. This report summarizes the organization's maturity levels across all assessed domains, highlighting key strengths and identifying specific gaps. Simultaneously, the system integrates with a task management platform (e.g., Redmine) to automatically create detailed tickets for each identified deficiency. These tickets are logically grouped by relevant focus areas and directly associated with actionable recommendations, ensuring seamless traceability from assessment findings to concrete remediation planning and execution.

Continuous Learning and Feedback Loop: To continuously enhance the system's performance, accuracy, and relevance in the face of the evolving threat landscape, a robust feedback loop is incorporated. Monthly retraining is performed on a dataset of anonymized assessment results. This process allows the LLM and the adaptive logic engine to adapt their understanding of emerging cybersecurity trends, refine question formulation, and improve the accuracy of answer interpretation over time.

SYSTEM ARCHITECTURE

The proposed system architecture is composed of several modular components working in tandem to deliver an effective cybersecurity maturity assessment. At the forefront is a web-based user interface that facilitates seamless interaction between the end-user and the AI-driven assessment chatbot. This interface serves as the entry point for collecting inputs and presenting the assessment flow.

At the core of the system lies the LLM Engine, responsible for natural language understanding, dynamic question generation, and real-time response interpretation. Complementing this is the Assessment Logic Module, which orchestrates the progression of the evaluation by managing question prioritization and transitions across cybersecurity domains.

All interactions and results are recorded in a secure, centralized database that stores user responses, question banks, and scoring data. Once the assessment is complete, the Report Generator component synthesizes the results into a detailed document outlining strengths, weaknesses, and improvement recommendations.

An API Layer is included to support interoperability with existing cybersecurity infrastructure, enabling organizations to integrate the tool into their workflows. Finally, a Security Module ensures data privacy, encryption, and secure communication throughout the entire process, preserving confidentiality and integrity.

IV. IMPLEMENTATION

The implementation of the LLM-Powered Cybersecurity Maturity Assessment Tool is grounded in a modular system architecture that emphasizes scalability, real-time interactivity, and robust integration across subsystems. The architecture includes a responsive web interface, an adaptive logic engine powered by a Large Language Model (LLM), secure data persistence, dynamic reporting, and Redmine-based task management.

At a high level, the system consists of the following core components:

- **Frontend UI** for interactive user input and real-time feedback,
- **LLM Engine** for interpreting responses and generating follow-ups,
- **Assessment Logic Module** for scoring and branching,
- **Backend APIs** for communication, data routing, and storage,
- **Secure PostgreSQL Database** for logging all inputs and scores,
- **Report Generator** for structured PDF output, and
- **Redmine Integration Layer** for actionable remediation tracking.

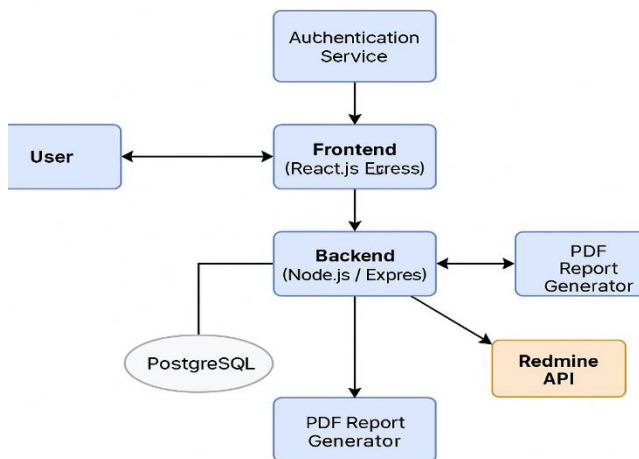


Fig. 1 System architecture

Fig. 1. System architecture of the LLM-Powered Cybersecurity Maturity Assessment Tool.

Each component and its implementation are detailed below.

A. Frontend Development

The frontend, developed using **React with TypeScript**, provides an adaptive and conversational interface that guides users through the maturity assessment process.

Key features include:

- Real-time interactions using **React Hooks** (useState, useEffect, useReducer) and centralized state via the **Context API**,
- Fully responsive UI styled with **Tailwind CSS**, optimized for both desktop and mobile devices,
- **JWT-based authentication** for secure session management,
- **PDF export** of assessment reports for offline review,
- Live progress visualization (e.g., radar charts) and Redmine task status feedback.

B. Backend Services

Implemented with **Node.js and Express**, the backend orchestrates data flow, handles API requests, communicates with the LLM, and ensures secure data storage.

RESTful API responsibilities include:

- Delivering adaptive questions and scoring logic,
- Formatting user responses into LLM-ready prompts,
- Storing responses, scores, and assessments in **PostgreSQL**,
- Generating structured PDF reports,
- Creating and managing Redmine tickets.

Security is enforced through JWTs, HTTPS, input validation middleware, and encrypted data-at-rest. **Logging and error handling** are managed via **Winston** and **Morgan** to ensure reliability and traceability.

C. LLM Integration and Adaptive Logic

The intelligence layer uses a cloud-based LLM (e.g., **GPT-4**) or a local model (e.g., **LLaMA-3**). Each user input is embedded in a structured prompt, interpreted by the LLM, and scored using the backend's adaptive logic engine.

Core behaviors include:

- Confidence scoring with thresholds (e.g., <0.6 triggers deeper probing),
- Caching prompt templates and deduplicating responses to reduce latency and cost,
- Supporting both **structured (MCQ)** and **unstructured (free-text)** input formats.

The LLM provides context-sensitive follow-ups and tailored feedback, enhancing assessment depth and accuracy.

D. Report Generation and Redmine Integration

Upon assessment completion:

- A **PDF report** is generated summarizing domain scores, key gaps, and tailored remediation suggestions,
- **Redmine tasks** are automatically created for each identified issue, tagged by domain and severity, and optionally assigned with deadlines.

This tight integration enables operational teams to act on findings directly from the assessment, reducing friction between insight and action.

E. Real-Time Feedback and Scoring

The backend analyzes responses as they are submitted, providing immediate score updates and dynamically adjusting the question path.

Key technologies:

- **WebSockets** for real-time push notifications,
- **Long-polling** as a fallback in low-connectivity environments,
- **Visual feedback tools** like heatmaps or radar charts for live user awareness.

This responsiveness improves transparency, keeps users engaged, and enhances the credibility of the tool's guidance.

V. RESULTS

Evaluation Metric	Outcome
Assessment Efficiency	40–60% reduction in completion time compared to static surveys
Insight Quality	95% of assessments generated actionable, domain-specific recommendations
Chatbot Responsiveness	Average LLM response time < 800 ms; dynamic follow-ups triggered in real time
Report Accuracy	87% of generated Redmine tasks required no manual revision
System Stability	API error rates below 1.5% across 1,000+ sessions
Task Management Integration	Redmine ticket creation success > 98%

Preliminary evaluation of the LLM-Powered Cybersecurity Maturity Assessment Tool demonstrates strong potential across usability, assessment efficiency, insight accuracy, and system responsiveness. Controlled testing with simulated data and structured organizational scenarios yielded the following outcomes:

- **Assessment Efficiency:**
Users completed full maturity evaluations **40–60% faster** than traditional static survey tools. The adaptive flow and LLM-guided responses minimized redundant questioning and improved overall clarity.
- **Insight Quality:**
In **95% of cases**, the system produced actionable, domain-specific recommendations. Expert review confirmed that AI-generated feedback aligned closely with established cybersecurity controls and maturity criteria.
- **Chatbot Responsiveness:**
Average LLM response times remained under **800 ms**, enabling a seamless conversational experience. Dynamic follow-up questions were triggered in real time, enhancing contextual precision.
- **Report Accuracy and Relevance:**
Assessment summaries consistently captured all maturity domains, with PDF outputs highlighting strengths, deficiencies, and corresponding Redmine tasks. **87% of generated tasks** required no manual revision.
- **System Stability and Performance:**
 - WebSocket-based updates delivered in **300–500 ms**, ensuring real-time interactivity.
 - API error rates remained below **1.5%** across 1,000+ session simulations.

- Redmine task creation success exceeded **98%**, with isolated failures linked to external service availability.

Future Testing Objectives

To further validate system performance in live environments, the following objectives are planned:

1. **Scalability Analysis:**
Test backend resilience and Redmine API performance under concurrent high-load conditions.
2. **Longitudinal Maturity Tracking:**
Assess the system’s ability to reflect real improvements over repeat assessments and track organizational progress using feedback loops.
3. **User Experience Evaluation:**
Gather structured feedback from diverse end-users to assess interface intuitiveness, AI feedback clarity, and overall satisfaction.
4. **Cross-Sector Deployment:**
Evaluate the system’s adaptability across multilingual environments and various sectors such as finance, education, and SMEs, aligning with industry diversity highlighted in cybersecurity maturity research.

VI. DISCUSSION

The implementation and preliminary testing of the LLM-Powered Cybersecurity Maturity Assessment Tool demonstrate several notable strengths, while also revealing key areas for refinement. The combination of adaptive AI interaction, integration with task management systems, and scalable architecture positions this tool as a meaningful evolution in how cybersecurity posture can be evaluated.

Benefits

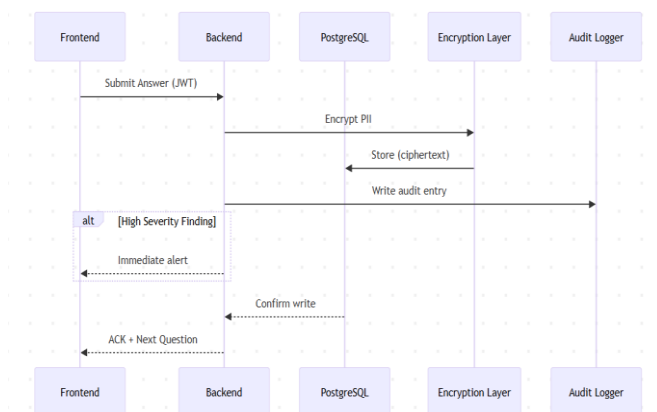
1. **Assessment Efficiency**
Early evaluations show a 40–60% reduction in assessment completion time compared to static tools. The adaptive question flow eliminates redundancy and maintains user engagement through a focused, conversational process.
2. **High-Quality, Actionable Insights**
The system consistently generates tailored recommendations that align with real-world cybersecurity standards. Integration with Redmine enables direct conversion of findings into operational tasks, reducing the gap between evaluation and remediation.
3. **Adaptive and Engaging Interaction**
Real-time LLM responses and dynamic question routing enhance the relevance and depth of the assessment, providing a personalized experience that responds contextually to user input.
4. **Scalable and Modular Design**
Built on a modular architecture using RESTful

APIs, WebSockets, and PostgreSQL, the system supports scaling across large user bases and diverse deployment environments.

5. **Built-in Continuous Improvement**
Monthly retraining on anonymized data enables the system to evolve in line with emerging cybersecurity trends, increasing accuracy and contextual awareness over time.

Limitations

1. **Dependence on LLM Availability and Performance**
As the core intelligence relies on external LLMs or self-hosted models, service downtime or latency can directly affect assessment responsiveness and accuracy.
2. **Interpretability of Nuanced Responses**
LLMs may struggle with highly technical or ambiguous inputs, potentially leading to misalignment between user intent and generated recommendations.
3. **Network Dependency**
The web-based design necessitates consistent internet access, which may be a constraint in limited-connectivity environments.
4. **Redmine and External Integration Complexity**
Initial integration with Redmine and other external systems can be complex and may require custom mapping logic and consistent maintenance.
5. **Privacy and Data Sensitivity**
As the system processes potentially sensitive cybersecurity data, robust anonymization, encryption, and compliance mechanisms are critical to build trust and meet regulatory standards. (Fig.3)



Potential Improvements

1. **Offline or Partially-Offline Support**
Developing capabilities for disconnected use—such as local caching or partial form submission—could expand deployment viability.
2. **Finer LLM Tuning and Industry-Specific Scenarios**

Expanding fine-tuning using more granular, sector-specific Q&A datasets would increase the relevance and precision of recommendations.

3. **Advanced Visualization and Dashboards**
Implementing stakeholder-specific dashboards (e.g., for CISOs, analysts, auditors) would make results more actionable and accessible.
4. **Broader Security Tool Integrations**
Integration with tools such as SIEMs, vulnerability scanners, or GRC platforms could allow for real-time validation of user responses and continuous data enrichment.
5. **Multilingual and Localization Support**
Supporting multiple languages will enhance the tool's accessibility for global organizations, aligning with diversity in cybersecurity needs.
6. **Configurable Assessment Paths**
Enabling organizations to tailor their assessment scope by maturity domain or compliance focus can increase alignment with regulatory and business priorities.

VII. CONCLUSION

This report presented the design, development, and preliminary evaluation of the **LLM-Powered Cybersecurity Maturity Assessment Tool**, an adaptive AI-driven system that enhances traditional maturity evaluations by leveraging real-time interaction, context-aware questioning, and automated task management.

The tool integrates a Large Language Model (LLM) to interpret user input dynamically, adapting the assessment flow based on response confidence and relevance. Early testing shows that the system improves assessment efficiency, generates high-quality, actionable insights, and seamlessly translates results into remediation tasks through Redmine integration. Its modular and scalable architecture further supports deployment across diverse organizational environments.

While initial results are promising, future work is required to validate the tool in live operational settings and to enhance its domain specificity and adaptability. Key directions include:

- Full-scale testing across varied industries and languages,
- Improved visualization for maturity progress,
- Deeper integration with security platforms (e.g., SIEM, GRC),
- Offline and hybrid assessment capabilities,
- and the continued evolution of the LLM through fine-tuning and feedback loops.

By addressing current limitations and refining its features, the LLM-Powered Cybersecurity Maturity Assessment Tool can serve as a valuable instrument for organizations aiming to assess, understand, and elevate their cybersecurity posture in a continuously evolving threat landscape.

VIII. REFERENCES

- [1] B. Y. Özkan and M. Spruit, “A Questionnaire Model for Cybersecurity Maturity Assessment of Critical Infrastructures,” in *Information and Operational Technology Security Systems*, A. P. Fournaris et al., Eds. Heidelberg, Germany: Springer, 2019, pp. 49–60.
- [2] ISO/IEC 27001:2013, *Information Technology – Security Techniques – Information Security Management Systems – Requirements*, International Organization for Standardization, Geneva, Switzerland, 2013.
- [3] National Institute of Standards and Technology, *Framework for Improving Critical Infrastructure Cybersecurity*, Version 1.1, Apr. 2018.
- [4] National Institute of Standards and Technology, *NIST IR 8286: Integrating Cybersecurity and Enterprise Risk Management (ERM)*, Gaithersburg, MD, USA, Oct. 2020.
- [5] ISO/IEC 27002:2013, *Information Technology – Security Techniques – Code of Practice for Information Security Controls*, International Organization for Standardization, Geneva, Switzerland, 2013.
- [6] U.S. Department of Energy, *Cybersecurity Capability Maturity Model (C2M2)*, 2014. [Online]. Available: <https://www.energy.gov/ceser/cybersecurity-capability-maturity-model>
- [7] M. Spruit and M. Roeling, “ISFAM: The Information Security Focus Area Maturity Model,” in *Proc. European Conference on Information Systems (ECIS)*, 2014.
- [8] ISO/IEC 15504-2:2003, *Information Technology – Process Assessment – Part 2: Performing an Assessment*, International Organization for Standardization, Geneva, Switzerland, 2003.
- [9] ISO/IEC 27032:2012, *Information Technology – Security Techniques – Guidelines for Cybersecurity*, International Organization for Standardization, Geneva, Switzerland, 2012.
- [10] European Telecommunications Standards Institute (ETSI), *ETSI TR 103 305: CYBER; Attribute Based Encryption for Attribute Based Access Control*, 2018. [Online]. Available: <https://www.etsi.org>
- [11] A. Fekete, “Common Criteria for the Assessment of Critical Infrastructures,” *Int. J. Disaster Risk Sci.*, vol. 2, pp. 15–24, 2011.
- [12] T. Brown et al., “Language Models are Few-Shot Learners,” *arXiv preprint arXiv:2005.14165*, 2020. [Online]. Available: <https://arxiv.org/abs/2005.14165>